

Izveštaj

Korak 1 - Login Bypass

- Otkrivanje ranjivosti u kodu uz pomoć statičke analize PHPStan.
- Otkrivena ranjivost u JWT tokenu
- Pisanje skripte koja će da eksploatiše te prethodno otkrivene ranjivosti aplikacije

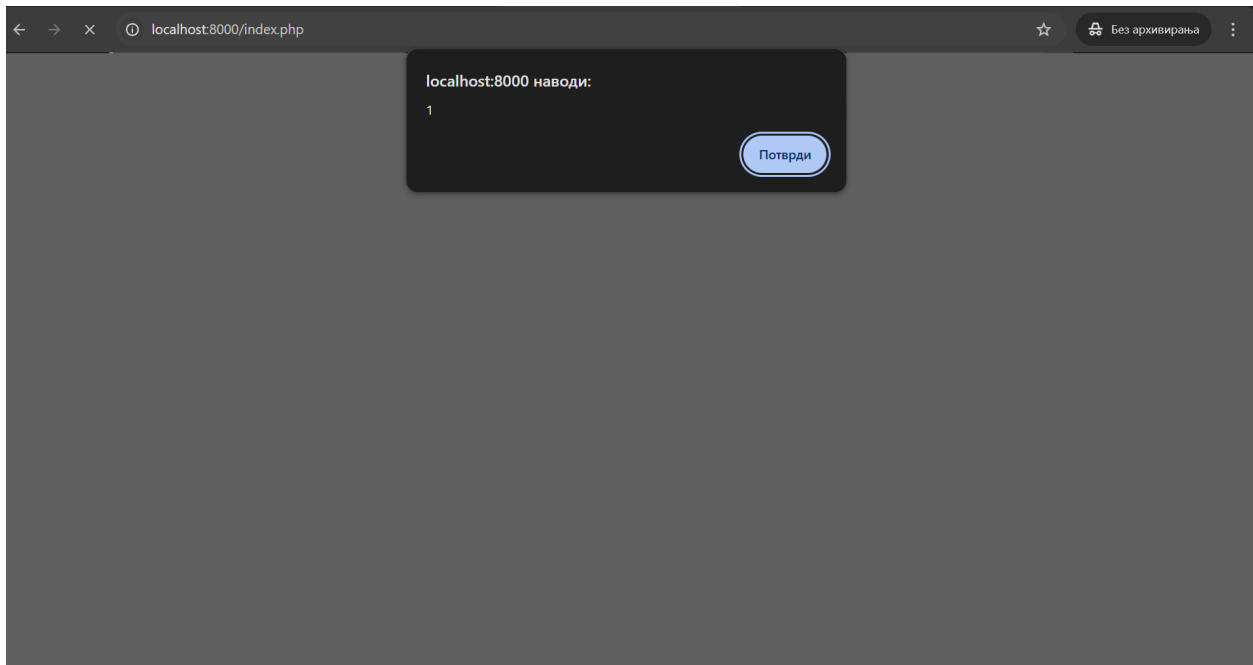
```
Windows PowerShell

Line  register.php
-----
10  Static method User::createcookie() invoked with 2 parameters, 1 required.
    arguments.count
59  File ends with a trailing whitespace. This may cause problems when running the code in the web browser.
    Remove the closing ?> mark or remove the whitespace.
    whitespace.fileEnd

Line  vendor\composer\InstalledVersions.php
-----
112  Offset 'dev_requirement' on array{pretty_version?: string, version?: string, reference?: string|null, type?:
    string, install_path?: string, aliases?: array<string>, dev_requirement: bool, replaced?: array<string>, ...}
    in isset() always exists and is not nullable.
    isset.offset
131  Parameter $parser of method Composer\InstalledVersions::satisfies() has invalid type
    Composer\Semver\VersionParser.
    class.notFound
131  Parameter $parser of method Composer\InstalledVersions::satisfies() has invalid type
    Composer\Semver\VersionParser.
    class.notFound
133  Call to method parseConstraints() on an unknown class Composer\Semver\VersionParser.
    class.notFound
    Learn more at https://phpstan.org/user-guide/discovering-symbols
134  Call to method parseConstraints() on an unknown class Composer\Semver\VersionParser.
    class.notFound
    Learn more at https://phpstan.org/user-guide/discovering-symbols
350  Call to function method_exists() with 'Composer\Autoload...' and 'getRegisteredLoaders' will always evaluate
    to true.
    function.alreadyNarrowedType

[ERROR] Found 26 errors

PS C:\Users\User\cr> |
```

TUDO -- An anonymous forum for discussing classes at the [Technical University of Denmark](#) © William Madsen, 2021 Logged in as: [admin](#), [Log out](#)

[Admin Section]

Uid	Username	Password (SHA256)	Description
1	admin	8c6976e5b5410415bde908bd4dee15dfb167a9c873fc4bb8a81f6f2ab448a918	BOSS
2	user1	0a041b9462caa4a31bac3567e0b6e6fd9100787db2ab433d96f6d178cabfce90	
3	user2	6025d18fe48abd45168528f18a82e265dd98d421a7084aa09f61b341703901a3	Head of Management

Import user:

[\[MoTD\]](#)

Hello, admin! Welcome to TUDO -admin :)


TU Freihaus


TU Hauptgebaude


TU Library

← → ↻

localhost:8000/profile.php

☆ 📄 | A ⋮

U.D.O -- An anonymous forum for discussing classes at the [Technical University of Denmark](#) 2021

Logged in as: [user1](#), [Log out](#)

My Profile:

Username:

user1

Password:

0a041b9462caa4a31bac35

Description:

Update

Success

←→🔄🔍localhost:8000/index.php

TUDO -- An anonymous forum for discussing classes at the *Technical University of Denmark* & William Mealy, 2021

Logged in as: [user1](#), [Log out](#)

[MoTD]

Hello, user1! Welcome to TUDO -admin :)



TU Freihaus



TU Hauptgebäude



TU Library

[All Posts]

Lva Code	Lva Name	Professor	ECTS	Comment
187.B12	Denkweisen der Informatik	Purgathofer, Peter	5.5	Very easy, but can be a bit frustrating
186.866	Algorithmen und Datenstrukturen	Kronegger, Martin	8.0	Pretty hard, but very interesting
184.735	Einführung in die Künstliche Intelligenz	Eiter, Thomas	3.0	Very lucky if you pass. Dont underestimate.
188.982	Privacy Enhancing Technologies	Weippl, Edgar	3.0	Very fun, and easy to get a perfect grade. Takes a lot of

←→🔄🔍localhost:8000/profile.php

TUDO -- An anonymous forum for discussing classes at the *Technical University of Denmark* & William Mealy, 2021

Logged in as: [user1](#), [Log out](#)

My Profile:

Username:

Password:

Description: